

SECURITY INCIDENT RESPONSE REPORT

Simulated Web Application Attack Campaign Against DVWA — Detected and Contained via Wazuh SIEM

Prepared by: Mudumala Varnika Narayani

Report date: September 27, 2026

Environment: Isolated home lab — VMware Workstation, NAT network

Monitored asset (agent): kali — 192.168.20.128 (Apache/DVWA web application)

SIEM / Manager: Wazuh 4.14.8 — manager.name: varnika, 192.168.20.132

Reporting period: September 18 – September 27, 2026

1. Executive Summary

This report documents a self-directed detection engineering exercise in which a deliberately vulnerable web application (DVWA) was attacked using seven distinct techniques — SQL Injection, Blind SQL Injection, Reflected XSS, Stored XSS, CSRF, and two brute-force variants — while a Wazuh SIEM deployment monitored, detected, classified, and in one case automatically contained the activity. All attacks were self-generated in an isolated lab for the purpose of validating detection coverage; no external systems were involved.

Seven custom detection rules (100010–100017, excluding 100013/100015 which serve as supporting building-block rules) were written, each mapped to a specific MITRE ATT&CK technique. All seven fired successfully against live attack traffic generated both manually and via Burp Suite Intruder. One rule (web brute-force, 100014) was additionally wired to an active response action, which automatically blocked the attacking host's IP via the local firewall within roughly 600 milliseconds of the alert firing.

2. Preparation

Environment

- Two VMware virtual machines on an isolated NAT network: a Kali Linux VM running Apache, MariaDB, and DVWA (the target), and an Ubuntu Server VM running the Wazuh Manager, Indexer, and Dashboard (the SIEM). Both VMs communicated privately within this NAT segment, with no exposure to the host network or internet.
- A Wazuh Agent installed on the Kali VM, configured to forward Apache access logs, Linux authentication logs (PAM/sudo), and file integrity monitoring (FIM/syscheck) events to the Manager.

Monitoring in place before the exercise began

- Web request logging — Apache access.log, decoded via Wazuh's built-in web-accesslog decoder (base rule 31100).
- Authentication logging — PAM login/logout and sudo execution events (rules 5501, 5502, 5402, 5403, 5407).
- File Integrity Monitoring — real-time syscheck watching the DVWA web root, generating alerts on unexpected file changes (rule 554, level 5).
- Seven custom rules written in local_rules.xml, each carrying a native <mitre> technique tag so that rule.mitre.id and rule.mitre.tactic populate automatically on every matching event.

3. Detection & Analysis

Each attack below was executed against DVWA, captured in Apache's access log, forwarded by the Wazuh Agent, and evaluated against the custom rule set. All alerts were verified directly in the Wazuh dashboard (Threat Hunting → Events), each showing populated rule.mitre.id and rule.mitre.tactic fields.

3.1 — SQL Injection (Rule 100010)

A UNION-based SQL Injection payload was submitted to DVWA's SQL Injection page, attempting to extract user credentials directly from the users table.

```
GET /DVWA/vulnerabilities/sqli/?id=1%27+UNION+SELECT+user%2Cpassword+FROM+users%23&Submit=Submit
```

- Detected: Sep 26, 2026 @ 15:48:44.859 — source 127.0.0.1, agent kali
- Rule 100010, level 10 — "Possible SQL Injection attempt on DVWA"
- MITRE: T1190 — Exploit Public-Facing Application (tactic: Initial Access)

- Also validated independently via Burp Suite (request captured, sent to Repeater/Intruder, response confirmed database extraction, Wazuh alert corroborated).

3.2 — Blind SQL Injection (Rule 100012)

A boolean-based blind SQLi payload was submitted, testing for a true/false condition without direct data extraction in the response.

- Detected: Sep 26, 2026 @ 21:12:31.9 — agent kali
- Rule 100012, level 10 — "Possible Blind SQL Injection attempt on DVWA"
- MITRE: T1190 — Exploit Public-Facing Application (tactic: Initial Access)

3.3 — Reflected Cross-Site Scripting (Rule 100011)

A `<script>` payload was submitted to DVWA's Reflected XSS page.

- Rule 100011, level 10 — "Possible XSS attempt on DVWA"
- MITRE: T1189 — Drive-by Compromise (tactic: Initial Access)

3.4 — Stored Cross-Site Scripting (Rule 100016)

A persistent script payload was submitted to DVWA's Stored XSS (guestbook) page, testing for script execution on every subsequent page load rather than a single reflected response.

- Detected: Sep 26, 2026 @ 13:57:34.4 — agent kali
- Rule 100016, level 10 — "Possible XSS Stored attempt on DVWA"
- MITRE: T1190 — Exploit Public-Facing Application (tactic: Initial Access)

3.5 — Cross-Site Request Forgery (Rule 100017)

A forged password-change request was constructed and submitted outside DVWA's normal form flow, simulating a victim's browser being tricked into submitting an unwanted authenticated action.

- Detected: Sep 27, 2026 @ 21:45:47.2 (also recurring Sep 26 @ 21:46:19.194) — agent kali
- Rule 100017, level 10 — "Possible CSRF attack on DVWA"
- MITRE: T1189 — Drive-by Compromise (tactic: Initial Access)

3.6 — Web Login Brute-Force (Rules 100013 / 100014)

Repeated login attempts were submitted to DVWA's Brute Force page, both manually and via Burp Suite Intruder (6–8 payloads fired in rapid succession), to trigger the frequency-based correlation rule.

- Rule 100013 (level 1) tags each individual request to the brute-force endpoint — a silent building-block rule, not an alert on its own.
- Rule 100014 (level 10) fires once 5–6+ tagged requests are seen from the same source IP within a 60-second window.
- Detected (manual test): Sep 26, 2026 @ 13:14:10.8 — "Possible brute-force attempt on DVWA (5+ login requests in 60 seconds)"
- Detected (Burp Intruder test): separate, independent firing confirmed against automated payload delivery.
- MITRE: T1110 — Brute Force (tactic: Credential Access)
- Total occurrences across the testing period: 13 (per exported Wazuh Threat Hunting Report, Sep 19–26 window).

3.7 — File Integrity Monitoring

As a secondary detection layer, real-time FIM (syscheck) was enabled on the DVWA web root. Two file-addition events were captured during the testing period, consistent with files being written into the monitored directory.

- Sep 25, 2026 @ 20:01:44.3 and Sep 25, 2026 @ 19:45:41.4 — agent kali
- Rule 554, level 5 — "File added to the system"
- MITRE mapping: T1565 — Data Manipulation (tactic: Persistence / Defense Evasion) — conceptual mapping for this rule class; FIM in this exercise served as a secondary layer independent of the primary web-attack rules.

4. Containment

An active response was configured on the Wazuh Manager, bound to the web brute-force rule (100014), using Wazuh's built-in firewall-drop command, targeted at the specific monitored agent rather than the manager's own host.

```
<active-response>    <disabled>no</disabled>    <command>firewall-drop</command>    <location>defined-agent</location>    <agent_id>001</agent_id>    <rules_id>100014</rules_id>    <timeout>600</timeout></active-response>
```

During the manual brute-force test on Sep 26, 2026, the containment action executed automatically and immediately after detection:

- 13:14:10.8 — Rule 100014 fires: "Possible brute-force attempt on DVWA (5+ login requests in 60 seconds)", level 10
- 13:14:11.4 — Rule 651 fires: "Host Blocked by firewall-drop Active Response", level 3 — the attacking IP is dropped at the firewall, roughly 600 milliseconds after detection
- The block was automatically lifted after the configured 600-second timeout (Rule 652 — "Host Unblocked by firewall-drop Active Response"), restoring normal access without manual intervention.
- Across the reporting period, the block/unblock pair fired 4 and 3 times respectively, corresponding to each repeated brute-force test run.

The other six attack types (SQLi, Blind SQLi, Reflected XSS, Stored XSS, CSRF) were configured for detection and alerting only, consistent with a real SOC's typical posture — automatic blocking is generally reserved for high-confidence, low-false-positive patterns like repeated authentication failures, while content-based web attacks are usually routed to an analyst for verification before any blocking action, to avoid disrupting legitimate traffic on a false match.

5. Eradication & Recovery

In this lab exercise, "eradication" refers to the underlying application fixes that would be applied in a real deployment, not to removing any actual compromise (none occurred — DVWA was deliberately vulnerable by design). For each technique observed, the corresponding real-world remediation is:

- SQL Injection / Blind SQL Injection — replace string-concatenated queries with parameterized queries / prepared statements; apply least-privilege database accounts.
- Reflected & Stored XSS — output encoding/escaping on all user-supplied data rendered back to the browser; a Content-Security-Policy header restricting inline script execution.
- CSRF — per-session anti-CSRF tokens validated on every state-changing request; SameSite cookie attributes.
- Brute-force — account lockout after N failed attempts, CAPTCHA after repeated failures, and rate-limiting at the web server or WAF layer, in addition to the SIEM-level detection already demonstrated.

No recovery actions were required on the monitoring infrastructure itself; the Wazuh Manager, Indexer, and Dashboard remained stable and continued ingesting events throughout testing (1,487 total events over the final 7-day window, 0 false level-12+ alerts).

6. Lessons Learned

- A single HTTP request is just a log; it only becomes a meaningful alert once a rule adds context — either content matching (SQLi/XSS signatures) or correlation across time and source IP (brute-force). Understanding this log → event → alert progression was the single most useful concept from this project.
- Small configuration details had an outsized effect on detection reliability during testing — a missing `ignore_case="yes"` on a URL match, or an unintentionally zero-width time range in the dashboard's date picker, both produced false "nothing detected" results despite the underlying rule logic being correct. Verifying with `wazuh-logtest` before trusting a live dashboard search saved significant troubleshooting time.
- Native MITRE ATT&CK tagging inside the rule definition itself (rather than a maintained-by-hand mapping table) meant every alert was automatically classified by tactic and technique, which made the dashboard's MITRE-based views immediately usable for trend analysis (e.g., seeing that Initial Access techniques dominated this exercise, as expected for a web-application-focused test).
- Active response is a meaningful escalation from detection to response, but it should be scoped narrowly — applying it only to the high-confidence brute-force rule (rather than every custom rule) reflected a deliberate choice to avoid the risk of a false positive on a content-matching rule causing a legitimate user to be blocked.
- Testing the same attack two ways (manual/curl and Burp Suite Intruder) confirmed that detection held up against both slow, human-paced traffic and fast, automated traffic — an important distinction, since some correlation rules (frequency/timeframe-based) behave very differently depending on how quickly requests arrive.

7. Alert Triage Log

A consolidated triage record of every alert type generated during this exercise, in the format a SOC analyst would use to track and close out alerts.

Rule	Timestamp (Sep 2026)	Source IP	Description	MITRE	Sev.	Action Taken	Status
100010	Sep 26, 15:48:44	127.0.0.1	Possible SQL Injection attempt on DVWA	T1190 (Initial Access)	High	Logged; verified via Burp	Closed — TP
100012	Sep 26, 21:12:31	—	Possible Blind SQL Injection attempt on DVWA	T1190 (Initial Access)	High	Logged for review	Closed — TP
100011	—	—	Possible XSS attempt on DVWA (Reflected)	T1189 (Initial Access)	High	Logged for review	Closed — TP
100016	Sep 26, 13:57:34	—	Possible XSS Stored attempt on DVWA	T1190 (Initial Access)	High	Logged for review	Closed — TP
100017	Sep 27, 21:45:47	—	Possible CSRF attack on DVWA	T1189 (Initial Access)	High	Logged for review	Closed — TP
100014	Sep 26, 13:14:10	192.168.20.128	Brute-force attempt on DVWA (5+/-60s)	T1110 (Credential Access)	High	Active response — IP auto-blocked 600s	Closed — TP, contained
554	Sep 25, 20:01:44	—	File added to the system (FIM)	T1565 (Persistence)	Med	Logged for review	Closed — TP, expected

TP = True Positive (all alerts in this exercise were deliberately generated, self-caused attacks, so all are true positives by design — there were no false positives observed in the level-10 custom rule set during the reporting period).

8. Coverage Summary

- 7 custom detection rules written and validated (100010, 100011, 100012, 100013, 100014, 100016, 100017)
- 4 MITRE ATT&CK techniques covered: T1190 (Exploit Public-Facing Application), T1189 (Drive-by Compromise), T1110 (Brute Force), T1565 (Data Manipulation)
- 2 MITRE tactics represented: Initial Access, Credential Access (plus Persistence/Defense Evasion via FIM and default PAM/sudo rules)
- 1 active response action configured and verified (firewall-drop on rule 100014, ~600ms detection-to-containment)
- 3 log sources monitored: Apache/DVWA web access logs, Linux PAM/sudo authentication logs, real-time File Integrity Monitoring
- 1,487 total events processed in the final 7-day reporting window, 0 level-12+ (critical) false alerts

This report, together with the accompanying 91-screenshot evidence set and the Wazuh-generated Threat Hunting Report, constitutes the full documentation for this project.